Лекция 5.

Транспортный уровень. TCP/UDP. NAT. ASA. DMZ

Транспортный уровень

- Осуществляет контроль за функциями сетевого уровня на приемном и передающем узлах (на промежуточных узлах протокол транспортного уровня не функционирует). Механизмы транспортного уровня проверяют целостность отдельных пакетов данных, последовательности пакетов, пройденный маршрут, время отправления и доставки, идентификацию и аутентификацию отправителя и получателя и другие функции. Все активные угрозы становятся видимыми на данном уровне.
- Гарантом целостности передаваемых данных является криптозащита как самих данных, так и служебной информации. Никто, кроме имеющих секретный ключ получателя и/или отправителя, не может прочитать или изменить информацию таким образом, чтобы изменение осталось незамеченным.
- Анализ трафика предотвращается передачей сообщений, не содержащих информацию, которые, однако, выглядят как реальные сообщения.
- Регулируя интенсивность этих сообщений в зависимости от объема передаваемой информации, можно постоянно добиваться равномерного трафика. Однако все эти меры не могут предотвратить угрозу уничтожения, переориентации или задержки сообщения. Единственной защитой от таких нарушений может быть параллельная доставка дубликатов сообщения по другим путям.
- Протоколы этого уровня предназначены для взаимодействия типа точка-точка. Пример: TCP, UDP, SCTP

- На транспортном уровне присутствуют два протокола - TCP и UDP. TCP используется для гарантированной передачи данных, в то время как UDP используется для передачи потоковых данных.

Функции TCP

- Использование портов - функция, которая позволяет определить для какого приложения предназначены данные, основываясь на номере порта (можно считать это адресацией транспортного уровня).
- Восстановление после ошибок - работает за счет подтверждений.
- Управление потоком с использованием окон - процесс, определяющий количество сегментов передаваемых до подтверждения.
- Установление и завершение соединений.
- Сегментация и упорядочивание передаваемых данных. Данные, разбитые на сегменты, должны быть собраны, после передачи, в том же порядке, в каком были разбиты изначально.

Использование портов

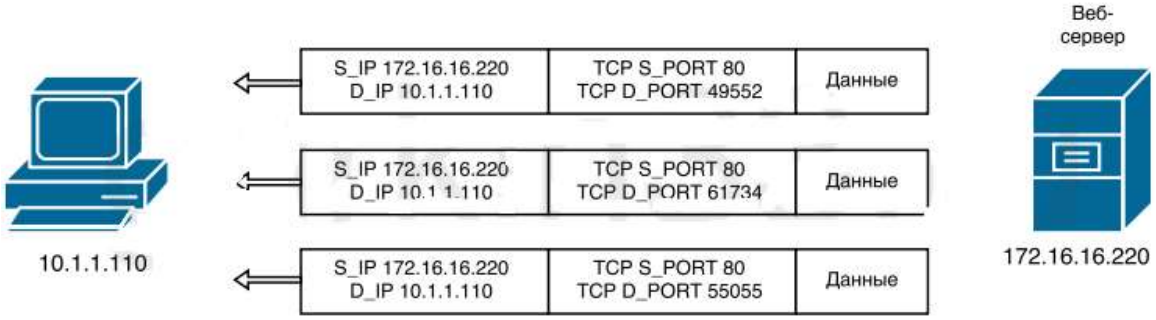
- TCP и UDP используют порты, которые в свою очередь, делятся на зарезервированные порты и динамические:
- с 1 по 1023 - зарезервированные порты (well-known ports, общеизвестные или системные);
- с 1024 по 49151 - зарезервированные порты (пользовательские);
- с 49152 по 65535 - динамически распределяемые порты.

Номер порта	Протокол Транспортного Уровня	Протокол Уровня Приложений
20,21	TCP	FTP
22	TCP	SSH
23	TCP	Telnet
53	TCP,UDP	DNS
67,68	UDP	DHCP
69	UDP	TFTP
80	TCP	HTTP
443	TCP	HTTPS

User Datagram Protocol (UDP)

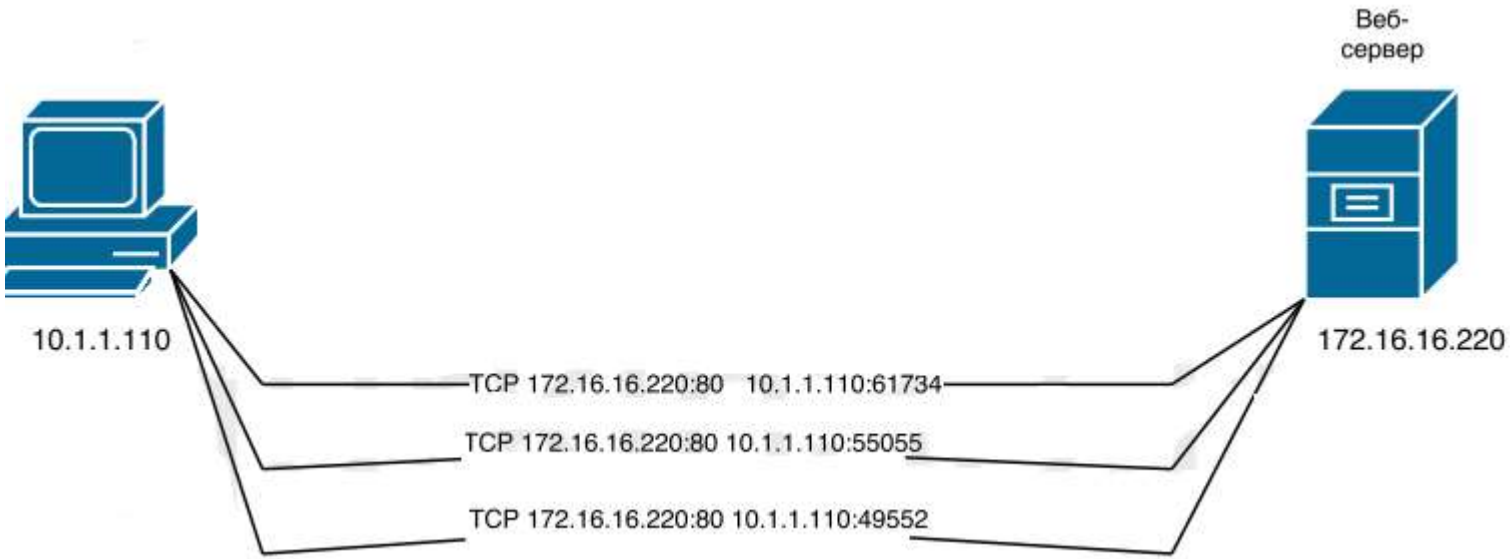
- У UDP нет сервиса восстановления данных после ошибок, он не ждет подтверждений о получении данных, нет окон, а так же сам заголовок очень мал, по сравнению с заголовком TCP.
- UDP используется для передачи потоковых данных, там где не нужны все те сервисы, которые может предложить TCP. К потоковым данным можно отнести IP-телефонию, видео-конференции. Популярное приложение Skype использует протокол UDP для передачи голосовых и видео данных.

- Наверно, самое часто используемое приложение - браузер. Часто мы открываем несколько "вкладок" с одним и тем же сайтом, и у каждой вкладки должно быть отличие, по которому компьютер сможет определить какой вкладке предназначены приходящие данные.



- Компьютер запросил с веб-сервера три веб-страницы (открыл три "вкладки" в браузере). Веб-сервер отправляет пакеты с одинаковыми заголовками (в заголовках одинаковые IP адреса), но заголовки сегментов различаются (обратите внимание на порт отправителя (S_PORT) и порт получателя (D_PORT)). Изначально компьютер привязал к каждому соединению определенный порт, который был определен случайным образом из динамически распределяемого диапазона (от 1023 до 65535), а обратился он на зарезервированный порт 80 (HTTP). Так происходит со всеми передаваемыми данными, к каждому приложению присваивается определенный порт/порты, таким образом данные получает то приложение, которому они предназначены.

Схематичное представление соединений



TCP и UDP могут устанавливать соединения с одинаковыми номерами портов, но при этом они будут считаться разными соединениями, так например, порт UDP 69 и порт TCP 69 - это два различных соединения.

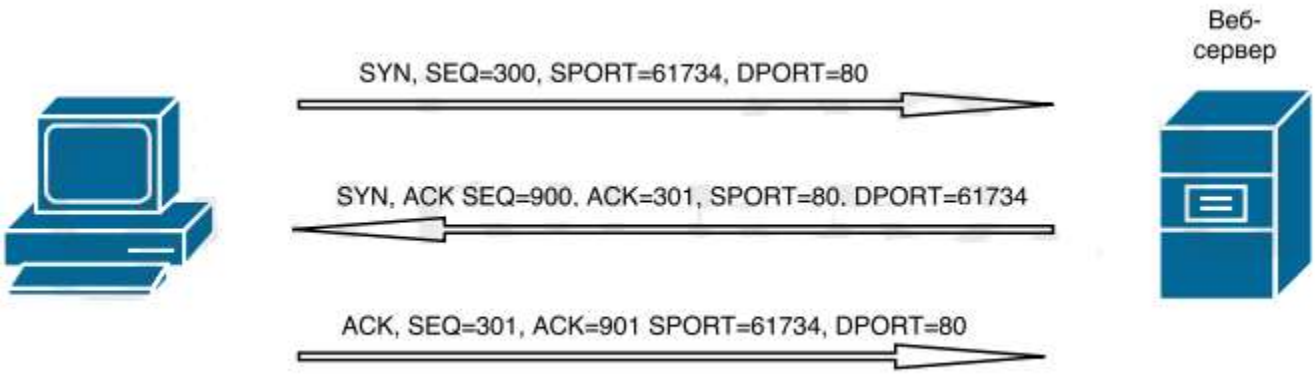
Сегментация

- Сегментация - разбивание данных на сегменты.
- Прежде чем данные будут переданы по сети они должны быть разбиты на сегменты, обычно не превышающие 1460 байт.
- Например, вы хотите передать видео файл размером 200Кбайт. Видео не будет передаваться одним целым файлом, оно будет разбито на сегменты, после чего по сети будут передаваться около 137 сегментов (200 000/1460~137)

Установление соединений

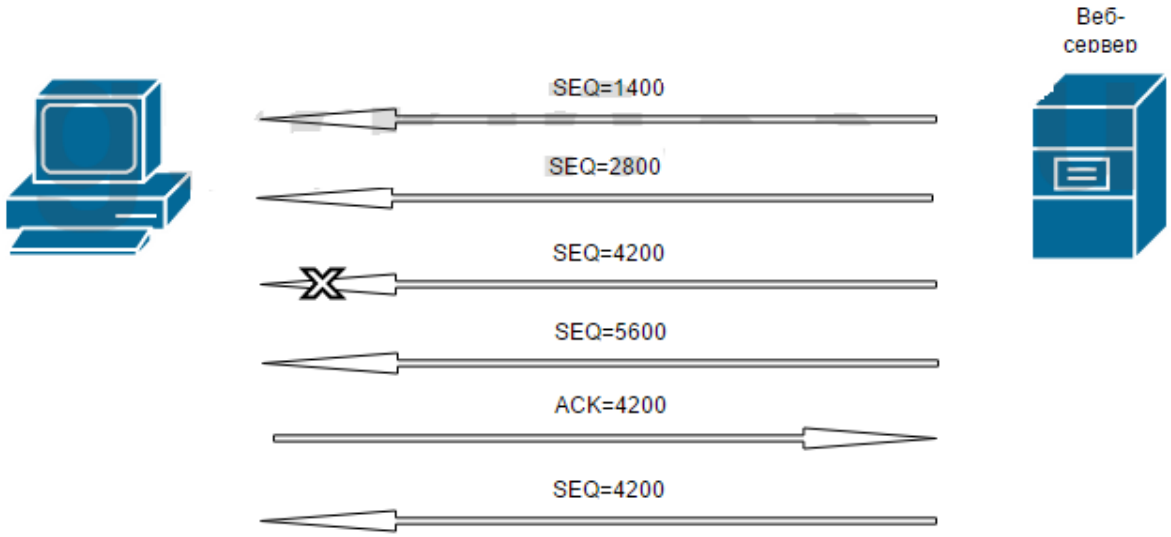
1. TCP устанавливает порт для приложения (для клиента, чаще всего, он находится случайным образом из диапазона от 1023 до 65535, в нашем примере, Source PORT 61734), определяет порт получателя/сервера (Destination PORT 80), случайно выставляет номер сегмента (SEQuence 300, каждый передаваемый сегмент имеет порядковый номер) и устанавливает параметр SYN (SYNchronization - этот параметр означает инициализацию соединения) в одно из полей заголовка сегмента (в каждом заголовке много разных полей - настроек, с помощью которых осуществляется одноуровневое взаимодействие). Такой сегмент приходит на сервер, который просматривает все, что приходит на 80-й порт.
2. Сервер формирует ответный сегмент, где он так же указывает порты отправителя и получателя. Но на этом шаге он указывает свой номер сегмента (случайно подобранный, SEQ 900), параметр SYN и новый параметр ACK (ACKnowledgment) - это подтверждение. В нашем примере параметр ACK равен 301, тем самым сервер подтверждает получение сегмента с номером 300, и ожидает получения сегмета с порядковым номером 301.
3. Третьим сообщением является ответ клиента на сегмент сервера, в нем указывается следующий порядковый номер (SEQ=301, а был SEQ=300) и подтверждается получение предыдущего сегмента от сервера (ACK=901, подтверждает получение сегмента SEQ=900).

Установка соединения TCP



Восстановление после ошибок

- Восстановление данных осуществляется за счет подтверждений (а обнаружение ошибок происходит на канальном уровне, за счет FCS(Frame check sequence ну или как мы говорили ранее CRC hash)).



- На рисунке изображена передача сегментов, и 3-й сегмент не приходит получателю. Введем некоторое пояснение, SEQ, помимо номера сегмента, обозначает количество переданных байт, например, первый сегмент 1400 байт, второй сегмент имеет такой же размер, но номер его 2800, он означает, что при получении этого сегмента будет передано уже 2800 байт. Вернемся к примеру, веб-сервер передает не сразу все сегменты, а по частям, ожидая подтверждения каждой части. Так например, если бы передача прошла успешно, веб сервер бы получил ACK=7000. В нашем примере 3-й сегмент потерялся, поэтому клиент отправляет подтверждение ACK=4200 (как бы спрашивая у сервера, "Где сегмент №4200?"), а сервер это будут трактовать как сегмент с номером 4200 был потерян, и веб-сервер отправляет его еще раз. Вот так и осуществляется востановление данных после ошибок.

Управление потоком с использованием окон

- Окно, в понятии TCP - количество сегментов передаваемых до подтверждения. Окно может менять свой размер, уменьшаться (сужаться), т.е. уменьшать кол-во передаваемых сегментов, при возникновении ошибок и расширяться при успешной передаче данных, т.е. увеличивать количество передаваемых сегментов.

Максимальная единица передаваемых данных (MTU)

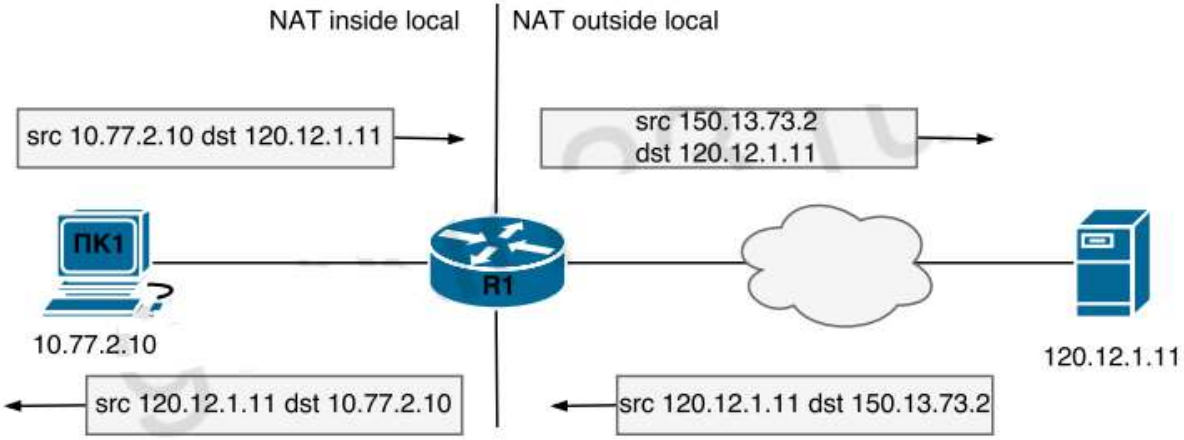
- Maximum Transmission Unit - это максимальный размер пакета, котрый может быть передан, без дробления на более мелкие пакеты. Этой величиной может управлять транспортный уровень, за счет увеличения или уменьшения сегмента.

NAT

- Появлялось все больше устройств, которые очень хотели выйти в Интернет и это опять начало приводить к быстрому истощению всего запаса ip адресов. Инженеры сетевых технологий придумали протокол под названием Network Address Translator. Эта технология позволяет скрывать сотни и даже тысячи устройств под одним ip адресом.
- Основная работа технологии NAT, это подмена ip адреса источника(source)/получателя(destination) в заголовке

Виды NAT

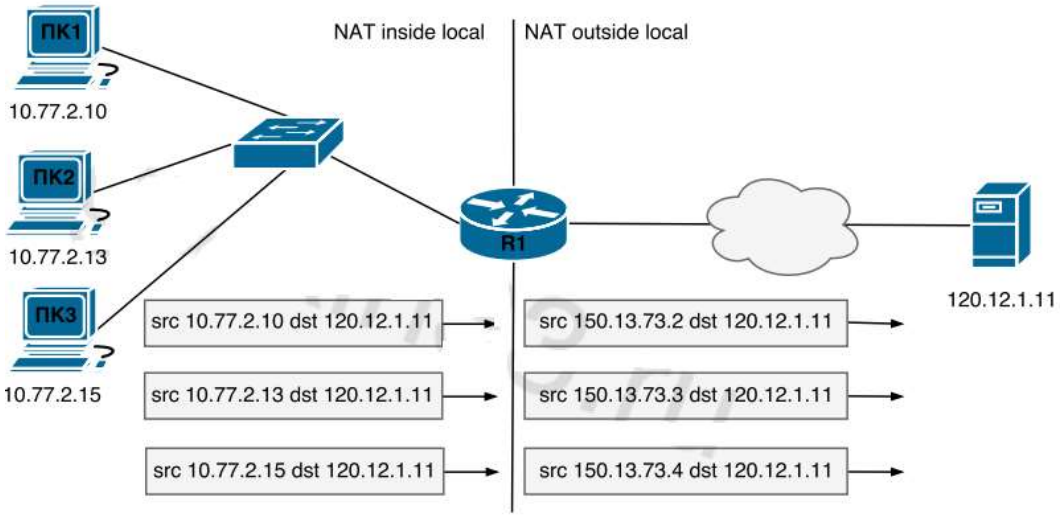
- Static NAT - позволяет скрывать одно устройство за одним ip адресом.



- Каждый раз, когда ПК1 отправляет данные в Интернет, R1 меняет ip адрес источника (src) и передает дальше. Таким образом устройства в интернете не видят реального ip адрес ПК1. В обратную сторону все работает аналогично, только в этом случае меняется адрес получателя (dst)

Dynamic NAT

- Dynamic NAT - позволяет скрывать несколько устройств за счет преднастроенного диапазона "внешних" адресов ("пул" адресов)

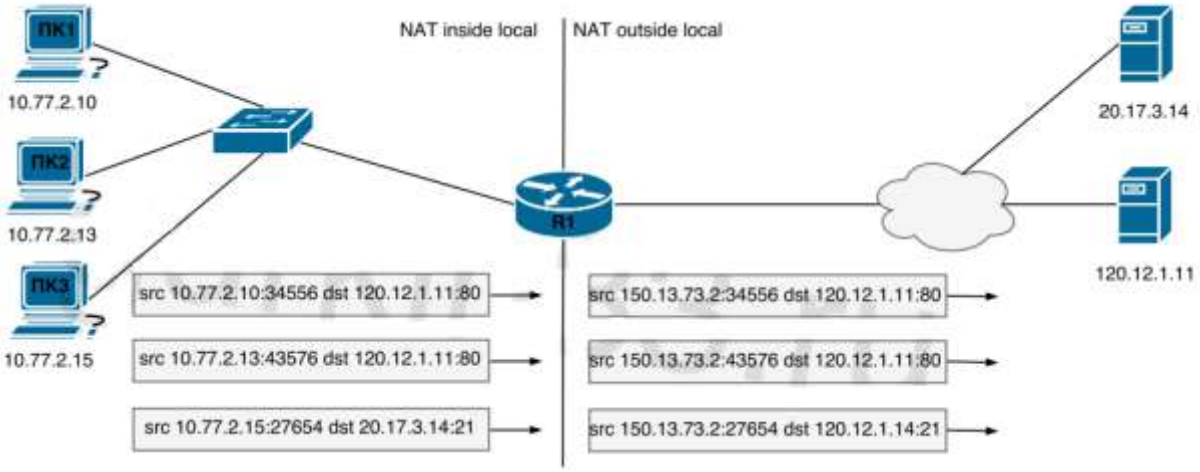


Dynamic NAT

- Каждый раз когда компьютеры выходят в Интернет, за каждым их них закрепляется один из внешних ip адресов. "Пул" внешних ip адресов задается вручную. Если устройств, которые хотят выйти в Интернет, больше, чем ip адресов в преднастроенном "пуле", то тут срабатывает правило - "кто успел, тот и съел". Если все внешние адреса разобраны, то остальным компьютерам (которые хотят выйти в Интернет) придется ждать, пока какой-нибудь из адресов не освободится.

Port Address Translator (PAT)

- Port Address Translator (PAT) - позволяет скрывать несколько устройств за один ip адрес. Такая схема работает за счет использования TCP/UDP портов.



Port Address Translator (PAT)

- src и dst (источник и получатель), далее идет запись типа ip адрес:порт. Порт веб-сервера 80, порт на стороне клиента выбирается случайным образом. Как вы можете видеть, после прохождения NAT, пакеты имеют один и тот же ip адрес, но разную адресацию портов, с помощью них роутер определяет, кому передать "вернувшийся" трафик.
- PAT - самый распространенный вид NAT, такое заключение можно сделать, хотя бы потому что все домашние роутеры используют PAT (D-link, Tp-link, ASUS и т.д.).

Публичные «белые» IP-адреса

- Публичный IP-адрес чаще называют «белым». С его помощью устройство может беспрепятственно выходить в интернет и общаться с другими устройствами, которые также обладают белым IP-адресом.

Частные «серые» IP-адреса

- Частный, или «серый», IP-адрес используется в локальных сетях. С таким адресом устройство может общаться с другими устройствами, только если они находятся в той же локальной сети.
- Чтобы как-то отличать белую и серую адресацию, во всем мире было принято решение выделить из общего диапазона адресов четыре подсети:
- 10.0.0.0 – 10.255.255.255 с маской 255.0.0.0;
- 172.16.0.0 – 172.31.255.255 с маской 255.240.0.0;
- 192.168.0.0 – 192.168.255.255 с маской 255.255.0.0;
- 100.64.0.0 – 100.127.255.255 с маской 255.192.0.0

ASA (Adaptive Security Appliance)

- Межсетевой экран – это маршрутизирующее устройство (третий уровень модели OSI). Основной задачей этого устройства является обеспечение сетевой безопасности. Устанавливается данное устройство как на границе сети Интернет, так называемый «Периметр», так и в сегменте серверов для обеспечения безопасности. При построении защищённой сети межсетевой экран – это главный компонент. Функции межсетевого экрана и маршрутизатора во многом схожи.
- Оба устройства поддерживают:
- - динамическую маршрутизацию (RIP, OSPF, EIGRP);
- - Трансляцию сетевых адресов (NAT – Network Address Translation);
- - Фильтрацию трафика, используя Access List;
- - VPN (Site-to-Site, RA VPN) — виртуальная частная сеть.

- Межсетевой экран Cisco ASA – это прежде всего устройство безопасности. И такие функции безопасности как межсетевой экран, IPS, VPN, подключение удаленных пользователей, с технической точки зрения реализованы лучше, чем на обычном маршрутизаторе.
- В межсетевых экранах по умолчанию включены многие функции безопасности, которые на маршрутизаторе необходимо настраивать вручную, либо они вообще отсутствуют.

Основные функции Cisco ASA:

1. Stateful packet inspection, SPI — инспекция пакетов с хранением состояния. Эта технология позволяет дополнительно защититься от атак, выполняя проверку проходящего трафика на корректность. Данная технология работает на сетевом, сеансовом и прикладном уровнях модели OSI.
2. Identity Firewall, IDFW – это технология, которая является эволюцией технологии файервола на сетевых экранах Cisco ASA. Главной особенностью технологии является возможность написания различных правил доступа (напр. ACL) относительно не IP-адресов, а конкретно для определенного пользователя или же группы пользователей. Это может быть очень удобно для сетей, где у пользователей нет фиксированных IP-адресов, т.е. в подавляющем большинстве компаний.
3. Архитектура Cisco TrustSec – это система управления безопасностью сети с помощью меток безопасности Secure Group Tag (SGT), которые по своему потенциалу несут если не революционный (хотя на мой взгляд именно такой), то уж точно намного более глубокий и продвинутый подход к формированию политик доступа в сеть с возможностью их детализации и применения прозрачно через всю сеть.
4. Улучшенный VPN (Virtual Private Network, виртуальная частная сеть — обобщённое название технологий, позволяющих обеспечить одно или несколько сетевых соединений (логическую сеть) поверх другой сети (например, Интернет).
5. Функция IPS – является встроенным решением для глубокого анализа сетевого трафика, которое помогает ПО Cisco IOS эффективно нейтрализовывать сетевые атаки.

- Межсетевой экран это в первую очередь фильтр. Использование межсетевого экрана исключительно для маршрутизации будет неправильным, тем более что многие функции доступны только в традиционных маршрутизаторах:
- - BGP (Border Gateway Protocol, протокол граничного шлюза) — динамический протокол маршрутизации;
- - MPLS (Multiprotocol Label Switching, многопротокольная коммутация по меткам) — механизм в высокопроизводительной телекоммуникационной сети, осуществляющий передачу данных от одного узла сети к другому с помощью меток;
- - DMVPN (Dynamic Multipoint Virtual Private Network — динамическая многоточечная виртуальная частная сеть) — технология для создания виртуальных частных сетей, разработанная Cisco Systems.

- Технология DMVPN является дальнейшим развитием VPN, и основывается на совместной работе протоколов разрешения шлюза NHRP, протокола туннелирования mGRE, шифрования IPSec и протоколов динамической маршрутизации: OSPF, ODR, RIP, EIGRP, BGP.
- - GRE (Generic Routing Encapsulation, общая инкапсуляция маршрутов) — протокол туннелирования сетевых пакетов, разработанный компанией Cisco Systems. Его основное назначение — инкапсуляция пакетов сетевого уровня сетевой модели OSI в IP-пакеты;
- - WLAN Controller – это контроллер беспроводной локальной сети, объединяющий точки доступа, управляющий их работой, а также централизующий трафик.

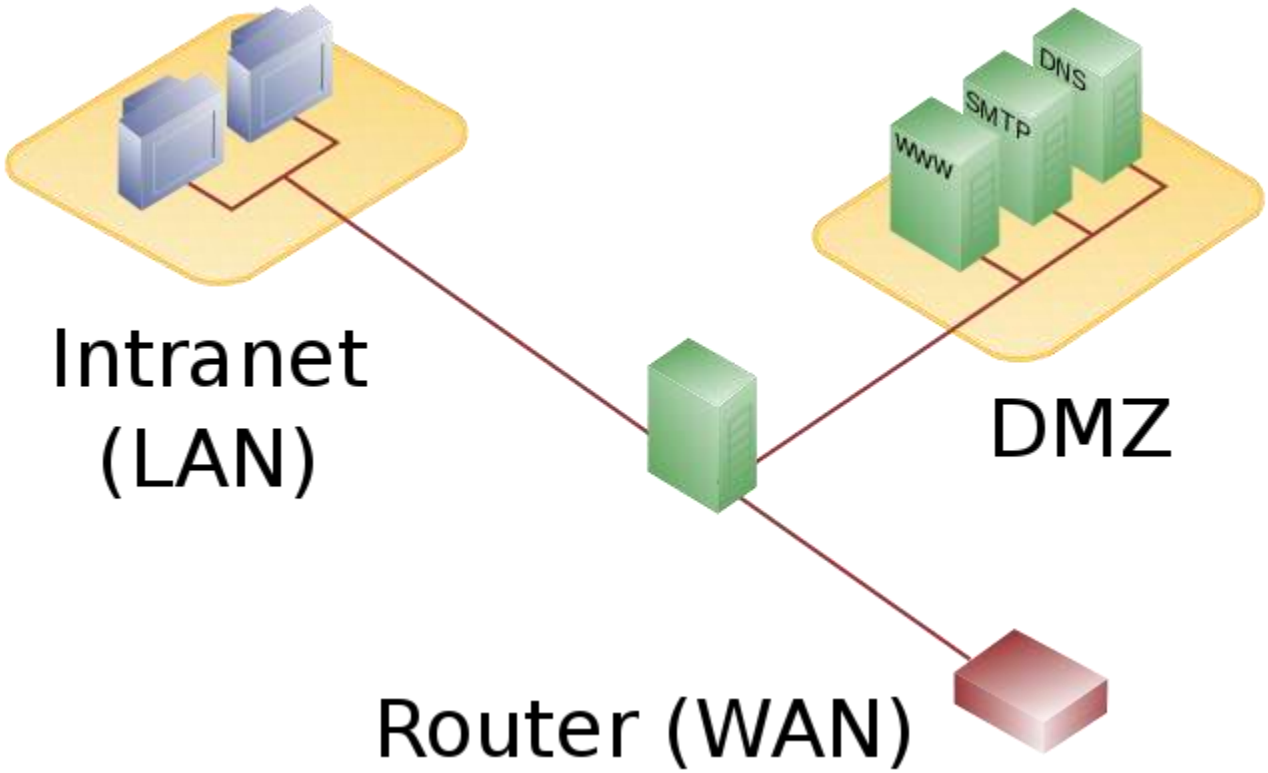
DMZ - Demilitarized Zone

- DMZ (демилитаризованная зона, ДМЗ) – сегмент сети, содержащий общедоступные сервисы и отделяющий их от частных. В качестве общедоступного может выступать, например, веб-сервис: обеспечивающий его сервер, который физически размещён в локальной сети (Интранет), должен отвечать на любые запросы из внешней сети (Интернет), при этом другие локальные ресурсы (например, файловые серверы, рабочие станции) необходимо изолировать от внешнего доступа.
- Цель ДМЗ – добавить дополнительный уровень безопасности в локальной сети, позволяющий минимизировать ущерб в случае атаки на один из общедоступных сервисов: внешний злоумышленник имеет прямой доступ только к оборудованию в ДМЗ.

- Системы, открытые для прямого доступа из внешних сетей, как правило, являются главными целями злоумышленников и потенциально подвержены проявлению угроз. Как следствие, эти системы не могут пользоваться полным доверием. Поэтому необходимо ограничить доступ этих систем к компьютерам, расположенным внутри сети.
- Предоставляя защиту от внешних атак, ДМЗ, как правило, не имеет никакого отношения к атакам внутренним, таким как перехват трафика.

- Разделение сегментов и контроль трафика между ними, как правило, реализуются специализированными устройствами – межсетевыми экранами. Основными задачами такого устройства являются:
- • контроль доступа из внешней сети в ДМЗ;
- • контроль доступа из внутренней сети в ДМЗ;
- • разрешение (или контроль) доступа из внутренней сети во внешнюю;
- • запрет доступа из внешней сети во внутреннюю.

- Для создания сети с ДМЗ может быть использован один межсетевой экран, имеющий минимум три сетевых интерфейса: один – для соединения с провайдером (WAN), второй – с внутренней сетью (LAN), третий – с ДМЗ. Подобная схема проста в реализации, однако предъявляет повышенные требования к оборудованию и администрированию: межсетевой экран должен обрабатывать весь трафик, идущий как в ДМЗ, так и во внутреннюю сеть. При этом он становится единой точкой отказа, а в случае его взлома (или ошибки в настройках) внутренняя сеть окажется уязвимой напрямую из внешней.


DNS
SMTP
WWW
Intranet
(LAN)
DMZ
Router (WAN)

- Более безопасным является подход, когда для создания ДМЗ используются два межсетевых экрана: один из них контролирует соединения из внешней сети в ДМЗ, второй – из ДМЗ во внутреннюю сеть. В таком случае для успешной атаки на внутренние ресурсы должны быть скомпрометированы два устройства. Кроме того, на внешнем экране можно настроить более медленные правила фильтрации на уровне приложений, обеспечив усиленную защиту локальной сети без негативного влияния на производительность внутреннего сегмента.

- Серверы, находящиеся в DMZ имеют, как правило, публичные белые ip-адреса.
- Для полноценной реализации DMZ сетевое устройство должно иметь возможность запоминать сессии. С помощью инспектирования трафика мы сможем запретить серверам DMZ инициировать соединения с локальной сетью.
- Тем самым мы защитим пользователей от злоумышленников, которые, возможно, взломали один из публичных серверов.
- При этом для самих пользователей локальной сети серверы DMZ будут по-прежнему доступны.

- DMZ можно организовать на межсетевом экране с помощью security-level, а также возможна реализация на маршрутизаторе с использованием zone based firewall или более старой технологией CBAC (Context Based Access Control).
- Как правило в любой профессиональной сети выделяют минимум три сегмента:
- 1. Внешний сегмент (outside);
- 2. DMZ-сегмент для публичных серверов (DMZ);
- 3. Внутренний сегмент (inside).